UNIVERSITY OF LONDON

BSc EXAMINATION 2024

For Internal Students of
Royal Holloway

DO NOT TURN OVER UNTIL TOLD TO BEGIN

IY3501/IY3501R: Security Management

for FIRST SIT/RESIT CANDIDATES

Time Allowed: **TWO hours**

Answer **THREE** questions.
No credit will be given for attempting any further questions.

Important Copyright Notice
This exam paper has been made available in electronic form
strictly for the educational benefit of current Royal Holloway students
on the course of study in question.
No further copying, distribution or publication of this exam paper is permitted.
By printing or downloading this exam paper, you are consenting to these restrictions.

©Royal Holloway, University of London 2024

Question 1. Information Security Management is a key part of modern business.

(a) Define the following terms:

(i) Information Security Management [2 marks]

(ii) Information Security Management System [2 marks]

(ii) Threat [2 marks]

(b) Briefly describe the **THREE** fundamental goals of the CIA triad and give an example of how each goal would apply to a university exam system. [12 marks]

(c) An attacker refers to an individual, group, or entity that carries out malicious activities with the intent of causing harm, exploiting vulnerabilities, or gaining unauthorized access to computer systems, networks, data, or other valuable assets. Briefly describe **FOUR** categories of attackers and compare their expected level of skill. [16 marks]

No further copying, distribution or publication of this exam paper is permitted.
By printing or downloading this exam paper, you are consenting to these restrictions.

Question 2. (a) Give a definition of risk in the context of information security management. [2 marks]

(b) Give a definition of 'risk culture' in the context of business management. [2 marks]

(c) One potential risk treatment is to **tolerate** the risk. Describe the other **THREE** treatments and give one example for each. [12 marks]

(d) The company SouthWestFuniture.com sells furniture online. Produce a risk assessment that identifies six risks. Each risk should include a) its likelihood, b) impact upon the company, c) total risk, d) suggested mitigation, e) a revised likelihood, f) revised impact and, g) revised total risk. [18 marks]

No further copying, distribution or publication of this exam paper is permitted.
By printing or downloading this exam paper, you are consenting to these restrictions.

Question 3. (a) Compare the terms Information Security Event and Information Security Incident and give an example of each. [6 marks]

(b) Give the name of the ISO standard that specifies information security controls for incident management. [2 marks]

(c) A company has had a break-in and the CEO's desktop computer is missing. List the **FIVE** phases of incident management and give an example of an action you would take in each phrase. [20 marks]

(d) Contrast the terms Disaster Recovery and Business Continuity and give an example of each. [6 marks]

No further copying, distribution or publication of this exam paper is permitted.
By printing or downloading this exam paper, you are consenting to these restrictions.

Question 4. (a) Define the following terms in the context of General Data Protection Regulation (GDPR):

(i) Personally Identifiable Information (PII) [3 marks]

(ii) PII Controller [3 marks]

(iii) PII Processor [3 marks]

(b) The 'Right of Access' is one of the eight rights that the GDPR grants to individuals. Please list **FOUR** of the remaining seven. [8 marks]

(c) A company selling tractors has collected email addresses from its customers in order to send them their receipts. Customers have not given explicit consent for other communication. Other than for receipts, give **TWO** examples of a circumstance in which this company could make use of the collected email addresses and **TWO** in which it cannot. [8 marks]

(d) Consider the statement: 'Companies have an ethical obligation to share personal data of suspected criminals with law enforcement authorities'. Do you agree or disagree with this statement? Justify your answer. [9 marks]

END

No further copying, distribution or publication of this exam paper is permitted.
By printing or downloading this exam paper, you are consenting to these restrictions.